

Instituto Politécnico Nacional — Escuela Superior de Cómputo

CuriTech — Servicio de Consultoría Especializada .NET

Matriz de Riesgos

La presente matriz de riesgos integra la valoración de los 9 activos de información de CuriTech (en sus dimensiones de Confidencialidad, Integridad y Disponibilidad), el análisis de vulnerabilidades y amenazas, el cálculo del riesgo y la identificación de infraestructuras críticas con sus controles, conforme a las mejores prácticas de gestión de riesgos de TI.

1. Valoración de Activos (C-I-D)

Escala 1-5 por dimensión. TOTAL = C + I + D. VALOR 1 = clasificación cualitativa; VALOR 2 = nivel numérico (3 = mayor criticidad).

| ACTIVO     |           |                                             | VALORACIÓN |   |   |       |         |
|------------|-----------|---------------------------------------------|------------|---|---|-------|---------|
| ID_PROCESO | ID_ACTIVO | ACTIVO DE INFORMACIÓN                       | C          | I | D | TOTAL | VALOR 1 |
| CT_SOP_01  | CT-ACT-01 | Sistema de gestión de tickets               | 4          | 4 | 4 | 12    | A       |
| CT_SOP_01  | CT-ACT-02 | Servidor de producción IIS                  | 4          | 5 | 5 | 14    | A       |
| CT_SOP_01  | CT-ACT-03 | Base de datos SQL Server (producción)       | 5          | 5 | 5 | 15    | A       |
| CT_MAN_02  | CT-ACT-04 | Repositorio de código fuente (Azure DevOps) | 5          | 5 | 4 | 14    | A       |
| CT_MAN_02  | CT-ACT-05 | Servidor de desarrollo y QA                 | 3          | 3 | 3 | 9     | Me      |
| CT_MAN_02  | CT-ACT-06 | Herramienta SonarQube                       | 2          | 3 | 2 | 7     | Me      |
| CT_MOD_03  | CT-ACT-07 | Pipeline CI/CD (Azure DevOps)               | 3          | 4 | 4 | 11    | A       |
| CT_MOD_03  | CT-ACT-08 | Ambiente de staging (Azure)                 | 3          | 4 | 3 | 10    | A       |
| CT_MOD_03  | CT-ACT-09 | Base de conocimiento y documentación        | 3          | 4 | 2 | 9     | Me      |

2. Vulnerabilidades, Amenazas, Eventos y Controles

| VULNERABILIDADES                                              | AMENAZAS                               | EVENTO DE AMENAZA (RIESGO)                         | CONTROLES           |
|---------------------------------------------------------------|----------------------------------------|----------------------------------------------------|---------------------|
| Acceso remoto VPN sin MFA completo, credenciales compartidas  | Ciberataque, robo de credenciales      | Acceso no autorizado a infraestructura del cliente | MFA obligatorio, V  |
| Cobertura insuficiente de pruebas de regresión en apps legacy | Error humano, defecto de código        | Caída de producción por despliegue fallido         | Pipeline CI/CD, pr  |
| Conocimiento crítico concentrado en pocos recursos            | Rotación de personal, indisponibilidad | Pérdida de continuidad operativa del servicio      | Base de conocimie   |
| Código fuente descargado en equipos locales sin DLP           | Fuga de información, robo de datos     | Exposición de información confidencial del cliente | Cifrado de disco, D |
| Dependencias legacy de .NET Framework sin actualizar          | Obsolescencia, explotación de CVEs     | Vulnerabilidad de seguridad en aplicaciones        | Escaneo de CVE, E   |
| Equipo reducido con dedicaciones parciales                    | Sobrecarga de incidentes simultáneos   | Incumplimiento de SLA                              | Escalamiento, aut   |

### 3. Análisis de Vulnerabilidades

Valor 3 = resultado de la combinación Severidad × Exposición (normalizado a escala 1-5).

| Análisis de Vulnerabilidades                 |           |            |
|----------------------------------------------|-----------|------------|
| Vulnerabilidades                             | Severidad | Exposición |
| Acceso remoto VPN sin MFA completo           | 4         | 3          |
| Pruebas de regresión insuficientes en legacy | 4         | 3          |
| Conocimiento concentrado en pocos recursos   | 3         | 3          |
| Código fuente local sin DLP                  | 4         | 2          |
| Dependencias legacy .NET sin actualizar      | 3         | 3          |

### 4. Análisis de Amenazas

Valor 4 = resultado de la combinación Capacidad × Motivación (normalizado a escala 1-5).

| Análisis de Amenazas           |                                  |           |            |
|--------------------------------|----------------------------------|-----------|------------|
| Amenazas                       | Eventos de amenaza               | Capacidad | Motivación |
| Error humano                   | Daño físico / lógico             | 2         | 2          |
| Ciberataque                    | Robo o alteración de información | 3         | 3          |
| Fallo de red / infraestructura | Indisponibilidad del servicio    | 2         | 2          |
| Rotación de personal           | Pérdida de conocimiento          | 2         | 3          |

### 5. Cálculo del Riesgo

Riesgo Total = Amenaza (Valor 4) × Vulnerabilidad (Valor 3) × Probabilidad × Impacto (TOTAL C-I-D del activo). Riesgo Alto ≥ 600 (rojo), Medio 400-599 (amarillo), Bajo < 400 (verde).

| Riesgo con control = Amenaza × Vulnerabilidad × Probabilidad × Impacto |                |              |         |
|------------------------------------------------------------------------|----------------|--------------|---------|
| Amenaza                                                                | Vulnerabilidad | Probabilidad | Impacto |
| 5                                                                      | 5              | 3            | 14      |
| 3                                                                      | 4              | 3            | 15      |
| 4                                                                      | 4              | 2            | 12      |
| 5                                                                      | 4              | 2            | 14      |
| 3                                                                      | 4              | 2            | 11      |

6. Valoración de Impacto por Activo

Evaluación del impacto considerando área geográfica, periodo de afectación, infraestructuras críticas afectadas, campos afectados e interdependencia. Criticidad en escala romana (I = menor, V = mayor).

| ACTIVO     |           |                               | VALORACIÓN      |                       |         |                           |                  |
|------------|-----------|-------------------------------|-----------------|-----------------------|---------|---------------------------|------------------|
| ID_PROCESO | ID_ACTIVO | ACTIVO                        | Área Geográfica | Periodo de Afectación | IMPACTO | Infra. Críticas Afectadas | Campos Afectados |
| CT_SOP_01  | CT-ACT-01 | Sistema de gestión de tickets | 3               | 2                     | 3       | 2                         |                  |
| CT_SOP_01  | CT-ACT-02 | Servidor de producción IIS    | 3               | 3                     | 3       | 3                         |                  |
| CT_SOP_01  | CT-ACT-03 | Base de datos SQL Server      | 3               | 3                     | 3       | 3                         |                  |
| CT_MAN_02  | CT-ACT-04 | Repositorio de código fuente  | 3               | 2                     | 3       | 2                         |                  |
| CT_MAN_02  | CT-ACT-05 | Servidor de desarrollo y QA   | 2               | 2                     | 2       | 1                         |                  |
| CT_MAN_02  | CT-ACT-06 | SonarQube                     | 2               | 1                     | 2       | 1                         |                  |
| CT_MOD_03  | CT-ACT-07 | Pipeline CI/CD                | 2               | 2                     | 3       | 2                         |                  |
| CT_MOD_03  | CT-ACT-08 | Ambiente de staging (Azure)   | 2               | 2                     | 2       | 2                         |                  |
| CT_MOD_03  | CT-ACT-09 | Base de conocimiento          | 2               | 2                     | 2       | 1                         |                  |

7. Identificación de Infraestructuras Críticas

| IDENTIFICACIÓN DE INFRAESTRUCTURAS CRÍTICAS |                     |                                                                     |
|---------------------------------------------|---------------------|---------------------------------------------------------------------|
| INFRAESTRUCTURAS CRÍTICAS DETECTADAS        | GRADO DE CRITICIDAD | CONTROLES A IMPLEMENTAR                                             |
| Servidor de producción IIS                  | V                   | Redundancia, balanceo de carga, UPS, monitoreo 24/7                 |
| Base de datos SQL Server (producción)       | V                   | Cifrado TDE, respaldos diarios, control de roles, auditoría         |
| Repositorio de código fuente (Azure DevOps) | V                   | Repositorios privados, control de cambios, MFA, versionado          |
| Sistema de gestión de tickets               | IV                  | Respaldos, control de accesos, redundancia en la nube               |
| Pipeline CI/CD (Azure DevOps)               | IV                  | Control de versiones, plan de rollback, validaciones automáticas    |
| Ambiente de staging (Azure)                 | IV                  | Aislamiento de producción, respaldos, control de accesos            |
| Servidor de desarrollo y QA                 | III                 | Respaldos periódicos, control de accesos                            |
| Base de conocimiento y documentación        | III                 | Integridad de documentos, respaldo en la nube, control de versiones |
| Herramienta SonarQube                       | II                  | Respaldo de configuración, control de accesos                       |